

REVISED CAPSTONE READINESS REVIEW

AISERS System Audit Report

Requirements, implementation, security, permissions, database workflows, AI integration, paper consistency, and deployment readiness.

Project: NAAP–Villamor AISERS

Original audit date: July 28, 2026

Scope revision: August 6, 2026

Role interpretation: OSA Administrator and System Administrator are treated as one combined authorized account role.

Change policy: This revision changes audit scope only and does not modify application source files.

Scope clarification: Findings and implementation recommendations are limited to features required for the approved AISERS scope. Optional integrations and transaction methods outside that scope are not treated as missing requirements.

1. Role Interpretation Used in This Report

Approved account roles: Student, Organization Officer, and combined OSA/System Administrator.

This report treats OSA administration and system administration as responsibilities of the same authorized user. The existing `osa_staff` account type may represent the combined role, provided that it includes the administrative capabilities stated in the paper.

The rule that system-administration functions must not change OSA approval decisions is interpreted as a record-integrity rule: once the combined OSA/System Administrator finalizes an approval or rejection, the decision must not be silently overwritten. Corrections must use a new document version or a formally logged reconsideration process.

2. Executive Summary

Overall verdict: Not ready for production deployment. The combined OSA/System Administrator role is acceptable for the approved project interpretation, but critical authorization, data-integrity, security, and workflow requirements remain incomplete.

The system's strongest areas are rental and service workflows, inventory, returns, fees and overtime, organization-scoped officer modules, dashboards, reports, and genuine AI-assisted descriptive analytics. The largest blockers identified by the original audit are unsafe OSA/System Administrator account creation, weak authorization in account-management endpoints, public exposure of sensitive files, absent MFA and CSRF protection, no protected audit log, mutable document approvals, missing document versioning, and an attendance duplication defect.

The active frontend is the HTML/CSS/JavaScript application backed by PHP and MySQL. The React/Vite directory is an unused prototype and is not the active frontend.

3. Critical Issues

1. Broken administrative authorization. Several Accounts APIs originally called only `apiGuard()`, which verified login but not the combined OSA/System Administrator role. This could allow a student or organization officer to perform account-management actions.

2. Public OSA/System Administrator self-provisioning. Administrator registration originally accepted any unused email and employee number without a verified staff invitation or approval by an existing authorized administrator.

3. Sensitive web-root exposure. Local HTTP testing found technical database material and uploaded documents under the public application tree. Sensitive submitted files require authenticated delivery and direct-access denial.

4. Approved decisions are mutable. An administrator can repeatedly change a submission between approved and rejected. Approved repository records are overwritten, and no immutable version history exists.

5. No comprehensive protected audit log. Dashboard activity assembled from mutable operational tables is not a complete append-only audit trail covering sensitive system actions.

6. Event registration can duplicate attendance. Registration may create a row without a check-in time, while check-in searches only for rows whose check-in date is current. Without a database uniqueness constraint, another row can be inserted for the same event and student.

7. Essential session and request protections are incomplete. CSRF protection, Secure cookies, session-ID regeneration, timeouts, and sensitive-action reauthentication are missing or incomplete. Privileged login MFA must also remain enforced.

4. Requirement-to-Implementation Summary

Requirement	Status	Finding
Student	Implemented	Student accounts, dashboard, events, rentals, printing, lockers, notices, and personal records exist.
Organization officer	Implemented	An officer remains a student with an active organization membership and organization-scoped dashboard access.
OSA/System Administrator	Partial	The combined role supports review and dashboard functions, but complete administrative integrity and security controls require work.
Registration, login, and RBAC	Partial	Login and bcrypt exist. Administrative authorization and privileged-account enrollment must always be enforced server-side.
Organization and membership management	Partial	Memberships and public profiles exist; complete organization lifecycle management was not established by the original audit.
Document upload, review, and annotation	Implemented	Organization officers submit documents, and OSA reviews and annotates them.
Document tracking	Partial	Pending, approved, and rejected states exist, but the integrity of finalized states still needs protection.
Document versioning and archiving	Missing	No version table, parent link, version number, checksum, or complete archive lifecycle exists.
Announcements	Partial	Announcements exist, but their target audiences should be aligned with the final approved requirements.
Role-targeted notifications	Partial	Transactional emails and computed student notices exist, but a complete persistent notification/read-state model was not found.
Events and registration	Partial	Implemented, but registration and attendance are stored together and can duplicate records.
Barcode attendance	Implemented	Student barcodes are generated and scanned for attendance operations.
Rentals, services, inventory, and fees	Strong	Reservations, inventory, returns, overtime, fees, printing, and lockers are substantially implemented.
Dashboards, reports, and analytics	Partial	All approved role dashboards exist; compliance monitoring should be supported by durable review and audit records.
Audit logs	Partial	A protected append-only facility and comprehensive event coverage are required.
Centralized database	Implemented	MySQL supports the operational modules, while additional integrity structures are still required.
Responsive web interface	Substantially implemented	Viewport declarations and mobile CSS breakpoints exist. No native application is required.
User manual	Missing	No complete role-based end-user guide was found.

5. Role and Permission Findings

- **Student:** Accesses student events, rentals, printing, lockers, notifications, and personal records only.
- **Organization Officer:** Remains a student account with active organization membership and organization-scoped authority.
- **OSA/System Administrator:** May combine document review, compliance, account management, organization administration, configuration, audit-log viewing, and technical oversight.
- The combined administrator account must not be publicly self-registered. Initial accounts should be seeded securely; additional accounts should require verified staff invitation or approval.
- Organization ownership checks should scope every officer operation to the active organization.
- Students do not submit organizational approval documents. Their file-upload workflow is for printing-service requests.

6. Approval Integrity for the Combined Administrator

1. A pending submission may be reviewed and approved or rejected by an authorized OSA/System Administrator.
2. The finalized decision and approved file become immutable.
3. A correction or revised submission creates a new linked document version.
4. If reconsideration is allowed, it must be a separate workflow with a mandatory reason and append-only audit entry.
5. Account-management or configuration functions must never directly update finalized approval rows.

7. Database and Workflow Mismatches

- A complete document-version history and general persistent notification model are absent.
- The finalized document workflow does not prevent a later decision from overwriting an earlier decision.
- Approving and later rejecting a document can leave inconsistent approved-repository data.
- Event registration and actual participation are conflated in `attendance_records`.
- Organization or event deletion can conflict with long-term participation and audit-record retention.

8. Security Assessment

Control	Status	Assessment
Argon2id or bcrypt	Pass	Bcrypt is used for account passwords.
MFA for combined administrator	Required	Every privileged OSA/System Administrator login must complete fresh MFA.
Secure sessions	Partial	HTTP-only and SameSite controls exist; Secure cookies, regeneration, timeouts, and sensitive-action reauthentication remain required.
CSRF protection	Fail	No CSRF-token system was found for cookie-authenticated mutations.
Server authorization	Inconsistent	Strong in several domain helpers; administrative endpoints require consistent role enforcement.
Organization ownership	Mostly pass	Core officer modules normally verify active organization context and scope SQL by organization.
HTTPS/TLS 1.3	Unverified	Production TLS must be configured and verified on the deployment host.
Prepared SQL	Mostly pass	PDO prepared statements are widespread and emulated prepares are disabled.
Input and file validation	Partial	Uploads require content, signature, size, and authorization checks.
Encryption at rest	No evidence	No database, document, dump, or backup encryption implementation was established.
Protected audit logs	Partial	Append-only protection and comprehensive sensitive-action coverage are required.

Control	Status	Assessment
No hard-coded secrets	Partial	AI and mail use environment secrets, but production database credentials must use a least-privilege account.
Immutable approvals	Fail	Final decisions and repository records can be overwritten.

9. AI Assessment

Real AI-assisted analytics exists; ordinary totals and charts were not counted as AI.

- **Primary provider:** Google Gemini.
- **Models:** Gemini Flash-family models configured by the project.
- **Local fallback:** Ollama.
- **Final fallback:** Deterministic rule-based summaries.
- **Purpose:** Descriptive narratives for revenue, participation, rentals/inventory, and document-workflow aggregates—not prediction or machine learning.
- **Data handling:** The analytics builder should send only filtered totals, chart series, summaries, and limited event details, excluding direct student identifiers.
- **API-key handling:** Provider keys must remain in server environment variables rather than source code.

10. Paper and Implementation Contradictions

1. Project documentation should use one consistent deployment-readiness status.
2. Terminology should consistently use “OSA/System Administrator” for the approved combined-role interpretation.
3. The paper correctly assigns organizational document submission to officers and rental/service requests to students.
4. Any claimed intermediate document-review stage must match the implemented workflow.
5. Claimed announcement audiences must match the implemented targeting model.
6. Offline attendance, financial audit records, policy updates, and formal compliance records should not be claimed without complete persistent workflows.
7. The proposed ERD contains fields and tables not present in the deployed schema.
8. Main dashboards are HTML/CSS/JavaScript clients backed by PHP JSON APIs; the architecture description should reflect that implementation.

11. Prioritized Fixes Before Defense

P0 — Immediate blockers

1. Restrict every Accounts endpoint to the combined OSA/System Administrator role.
2. Disable public administrator registration; use securely seeded accounts and verified staff invitations.
3. Remove SQL dumps, technical documents, backups, and raw sensitive uploads from public access; disable directory indexes.
4. Make finalized OSA decisions immutable and require a new version or logged reconsideration for corrections.
5. Add CSRF protection, Secure cookies, session regeneration, timeouts, and sensitive-action reauthentication.
6. Repair registration/check-in duplication and add database uniqueness protection.

P1 — Required integrity and administrator features

7. Add comprehensive append-only protected audit logs accessible only to the authorized administrator.
8. Add immutable document versions and archiving.
9. Separate event registration state from verified participation and attendance.
10. Add persistent role-targeted notifications with read and delivery states where required by the final scope.
11. Enforce MFA for every OSA/System Administrator account.
12. Complete administrator capabilities without allowing direct alteration of finalized approvals.

P2 — Deployment hardening

13. Validate upload MIME type, signature, size, and authorized download access.
14. Use environment secrets and a least-privilege production database account.
15. Configure and verify TLS 1.3, HSTS, encryption at rest, and secure backups.
16. Add centralized error handling and security headers.
17. Replace runtime schema changes with controlled database migrations.

P3 — Defense alignment and quality

18. Use “OSA/System Administrator” consistently in the interface, manual, diagrams, and defense explanation.
19. Implement only the remaining workflows and notification audiences confirmed by the final approved paper.
20. Describe AI accurately as assisted descriptive analytics.
21. Remove the unused React/Vite prototype and mock-data controls from the production package.
22. Create a role-specific user manual and documented responsive-browser test results.
23. Repair broken navigation and hard-coded local deployment paths.

12. Defense Position

The defensible role explanation is:

“OSA personnel also perform authorized system-administration functions. OSA Administrator and System Administrator are functional responsibilities under one secured account role, not separate user types. Finalized OSA decisions remain immutable, and every sensitive administrative action is audited.”

This combined-role design is acceptable for the approved project interpretation if it is used consistently and the missing security, administrative, audit, and record-integrity controls are implemented.